PLAYBOOK DE RESPUESTA

PB-08 | Cuenta privilegiada nueva o elevación

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar cuentas ADMIN, sudoers o roles superusuario de PostgreSQL no autorizados.

02. Disparador, fuente y umbral

Wazuh Windows EventChannel / Ubuntu auth y FIM; reglas locales de PostgreSQL. Umbral: cualquier grant de superusuario sin autorización se clasifica Alta.

03. Severidad inicial y promoción

Alta por defecto; Crítica cuando se confirma nueva cuenta privilegiada no autorizada en réplica/producción o abuso de llaves.

04. Triage: validación paso a paso

1. Revisar creación de cuenta, grupo/rol, emisor, usuario y sesión de origen.
2. Determinar el impacto del rol sobre C05-SRV-02 y base transaccional.
3. Verificar autorización previa y ventana de mantenimiento.
4. Consultar uso posterior de nueva cuenta, creación de tokens o alteración de permisos.
5. Cruzar con accesos anómalos y cambios FIM en archivos de aplicación.

05. Contención autorizada a N1

- Preservar logs y solicitar a administrador o N2 suspender privilegio no autorizado.
- Notificar al responsable SOC por amenaza potencial a datos financieros.

06. Acciones no autorizadas a N1

- No borrar usuario, revocar roles ni ejecutar SQL de reversión desde N1.
- No exponer secretos o volcado de datos de clientes para demostrar evidencia.

07. Evidencia mínima preservada

- Eventos de grupos/roles, sentencia saneada, hora, actor, activo y autorización.
- Registro de sesión y accesos posteriores.

08. Escalamiento obligatorio a N2

Siempre si no existe autorización documentada; de inmediato si es BD de pagos.

09. Criterios de cierre técnico

La autorización válida se adjunta y la actividad se clasifica como cambio aprobado; otros casos a N2.

10. Mejora continua

Auditar CREATE ROLE y membresías; MFA/PAM para administradores.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-08 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.